Course Code: ITA1439

Course Name: Ethical Hacking **Slot: A**

CO1 – ASSIGNMENT_1

Nature of Assignment: Individual **Duration: 1 Week**

Total Marks: 50

Student Name: A. Govardhan Reddy **Reg. No:192421359**

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity. **Assignment Title:** Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Scenario - University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are

set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

1.1 Systems in scope (initial programme: about 20 systems)

Every system receives a permanent **Asset ID** (SYS-nnn) in a central **Asset Register**. Nothing can be tested unless its Asset ID appears in a signed scope annex.

Group	Systems (Asset IDs)	Count	Environment	Holds personal data?
Student portal	Web front end (SYS-001), application server (SYS-002), student database (SYS-003)	3	Production	Yes – identity, marks, contact data
Learning-management system	Web (SYS-004), app server (SYS-005), database (SYS-006), file store (SYS-007)	4	Production	Yes – submissions, grades
Email service	Mail gateway (SYS-008), webmail (SYS-009), directory sync (SYS-010)	3	Production (SYS-009 may be cloud-hosted → provider permission needed)	Yes – mailbox content
Campus network	Core switch (SYS-011), firewall (SYS-012), Wi-Fi controller (SYS-013), DNS/DHCP (SYS-014), identity provider/AD (SYS-015), VPN gateway (SYS-016), NAC (SYS-017)	7	Production	Partly – logs, identities
Pre-upgrade staging clones	Portal staging (SYS-018), LMS staging (SYS-019), mail staging (SYS-020)	3	Staging	No (masked data only)
Total		**20**		

(In the walkthrough, SYS-016 and the exam server are treated as exclusions to demonstrate out-of-scope detection; the register is the single source of truth.)

1.2 Stakeholders

Stakeholder	Interest / role in the framework
Governance Team (us)	Designs, maintains and audits the framework
CISO / Security Lead	Approver for standard engagements; owner of risk
Registrar, LMS owner, IT head (system owners)	Own the assets, accept risk, remediate findings
Data Protection Officer (DPO)	Must clear any engagement that touches personal data

Stakeholder	Interest / role in the framework
Legal Counsel	Interprets the IT Act 2000, DPDP Act 2023 and contracts
Requesting department head	Raises the testing request, funds remediation
Internal testers (about 50 staff)	Perform assessments under the code of conduct
External / third-party assessors	Perform assessments under contract and NDA
Students and staff (data principals)	Their data and availability must be protected
Network Operations Centre (NOC)	Monitors, receives "stop" calls, manages change windows
CERT-In, vendors, cloud providers	External parties for reportable incidents and vendor-side vulnerabilities

1.3 Expected activities and constraints

Activities: request → risk tiering → legal/data-protection check → written authorization → scope and RoE sign-off → threat-model rehearsal in the isolated lab → authorized assessment (staging first, then live within windows) → finding report → coordinated disclosure → retest and closure.

Constraints: (C1) live systems must stay available; (C2) personal data must not be copied or exposed; (C3) Indian law applies, with international law as a benchmark for external assessors; (C4) about 50 staff and 20 systems now, growing to the whole university and third parties; (C5) the upgrade date is fixed, so approvals must be fast; (C6) no exploitation outside the lab in this assignment; (C7) results must be disclosed in a coordinated, time-bound way.

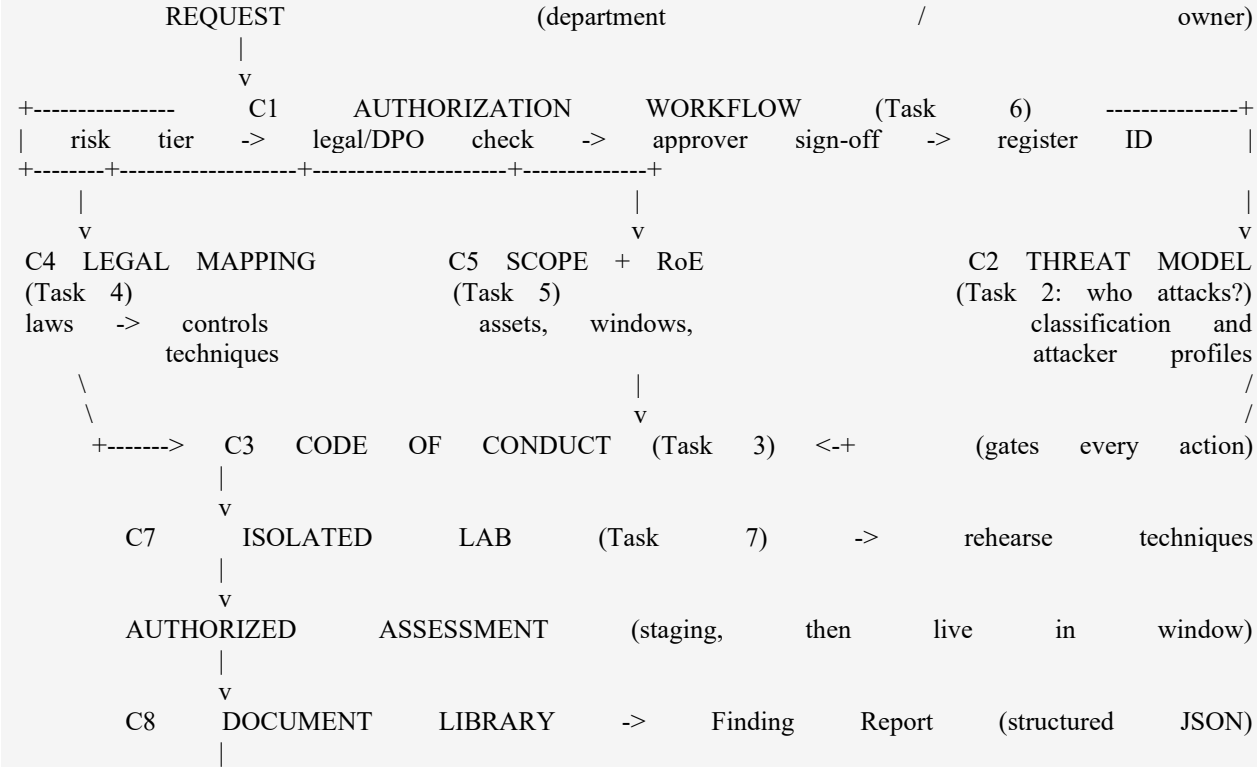
1.4 Formal engagement-governance requirements

ID	Requirement ("shall" statement)	Traced to scenario concern
GR-01	No test shall start without written authorization from an authorized approver, recorded under a unique Engagement ID.	Unauthorized access
GR-02	Every target shall be identified by an Asset ID that appears in the signed scope annex.	Unclear scope
GR-03	Each engagement shall have a Rules-of-Engagement (RoE) document stating windows, permitted/prohibited techniques and escalation paths.	Damage to live systems
GR-04	Engagements touching personal data shall be cleared by the DPO and Legal before approval.	Legal exposure, personal data
GR-05	Every authorization and activity shall be logged, with logs kept at least 180 days.	Accountability
GR-06	All testers shall accept the Code of Conduct and be classified as "white-hat" only while inside authorization.	Ethics, trust

ID	Requirement ("shall" statement)	Traced to scenario concern
GR-07	Hands-on techniques that could disturb systems shall be rehearsed only in the isolated lab (192.168.56.0/24, host-only).	Damage to live systems
GR-08	Every finding shall be reported in the standard format and disclosed through the coordinated-disclosure process.	Uncoordinated disclosure
GR-09	The framework shall support risk tiers so that low-risk requests are approved faster than high-risk ones.	Growth, speed
GR-10	External assessors shall have an NDA, a contract clause on data handling and a higher approval tier.	Third parties
GR-11	The framework shall distinguish what is *authorized*, what is *legal* and what is *appropriate*, and require all three before testing.	Brief of the scenario
GR-12	Components shall exchange data through defined identifiers (Engagement ID, Asset ID, Finding ID).	Integration

The three-way distinction (GR-11): *Authorized* = a named person with authority has signed in writing. *Legal* = the act is permitted under IT Act, DPDP Act and contracts (authorization from the wrong party, or for systems the university does not own, does not make an act legal). *Appropriate* = consistent with university ethics and risk appetite (e.g. no phishing of students even if technically authorized). **A test proceeds only when all three tests pass.**

1.5 Framework blueprint – requirements-to-governance



v
C6 DISCLOSURE LAYER (Task 6) -> remediation -> closure

How the parts cooperate: the Authorization workflow cannot reach APPROVED until Legal (C4) and Scope/RoE (C5) pass; the Code of Conduct (C3) is checked at every action; the Threat Model (C2) decides which attacker profile the test emulates and which techniques are useful; the Lab (C7) is the only place for risky techniques; the Finding Report (C8) carries the Engagement ID and Asset ID so the Disclosure layer (C6) can verify scope, DPO clearance and deadlines.

1.6 Enquiry questions the framework must answer

No.	Enquiry question	Answered by
EQ1	Who authorizes a test, in what form, and how is that authorization verified and recorded?	Tasks 5, 6, 8 (Authorization Form, AV rules, workflow)
EQ2	What exactly is in scope, and how can an out-of-scope request be detected automatically?	Task 5 (Asset IDs, scope manifest, S-rules)
EQ3	Which laws apply, and what happens when a test touches personal data?	Task 4 (legal mapping, applicability decision)
EQ4	How are findings disclosed, to whom, and when may disclosure proceed?	Task 6 (CVD process, can_disclose rules)
EQ5	Which attackers do we emulate and how do we classify an actor consistently?	Task 2
EQ6	How do we stop an engagement from becoming unethical or harmful, and how do we keep hands-on testing contained?	Tasks 3 and 7
EQ7	Does the framework still work when the programme grows ten-fold or requirements tighten?	Tasks 10 and 11

1.7 Design criteria (acceptance criteria for the final framework)

ID	Design criterion	Acceptance test (pass condition)
DC1	**Authorization completeness** – no activity without signed authorization	100% of negative test cases with missing/invalid authorization are REJECTED (Task 9)
DC2	**Scope precision** – out-of-scope targets are detected	≥ 95% of mis-scoped targets caught in the large-programme simulation (Task 10)
DC3	**Legal traceability** – each legal requirement maps to a control	Zero legal rows in the mapping table without a control ID (Task 4)
DC4	**Containment** – hands-on testing cannot leave the lab	Lab validator rejects any config with a non-host-only adapter, gateway or out-of-range IP (Task 7)
DC5	**Disclosure timeliness** – findings are remediated/disclosed on a defined clock	Every finding has a severity-based due date; delay case handled (Tasks 6, 9)
DC6	**Scalability** – approval turnaround stays practical at 20× growth	Mean approval turnaround ≤ 1 working day at large scale (Task 10)

ID	Design criterion	Acceptance test (pass condition)
DC7	**Reusability and integration** – documents are reusable and linked by IDs	Finding report JSON accepted by the disclosure gate without manual re-entry (Task 8)
DC8	**Ethical clarity** – the Code of Conduct separates acceptable, borderline and unacceptable actions	All 9 scenario cases give the expected verdict (Task 3)

1.8 Rationale

The scenario's risks (unauthorized access, legal exposure, damage, unclear scope, uncoordinated disclosure) each map to a requirement (GR-01 to GR-12), a component and a design criterion. Using IDs as the "glue" lets the framework grow from 20 systems to a whole university without redesign, and the tiered approach prevents the governance team from becoming a bottleneck.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

2.1 Classification model and criteria

An actor is classified on four observable attributes, applied in a fixed order so two reviewers get the same answer.

Attribute	Values	Question
A – Authorization	Authorized / Unauthorized / Exceeded	Is there written, in-scope authorization for the act?
I – Intent	Protective / Curiosity-disclosing / Financial / Ideological / Espionage-strategic / Malicious-personal	What outcome does the evidence show the actor wants?
P – Position	Internal (valid account or physical access) / External	Does the actor hold legitimate credentials or access?
K – Capability	L (uses ready-made tools) / M (adapts tools, scripts) / H (develops exploits, persistent campaigns)	What skill and resources are shown?

Naming convention: `H<n>-<Type>[<tags>]`, for example `H3-GreyHat[P:Internal][K:M]`. The primary type comes from A and I; position and capability are tags.

Ordered decision rules (first match wins):

1. A = Authorized and acts inside scope → **H1 White-hat**. If A = Exceeded → reclassify by rules 2–8 for the excess acts and raise a Code-of-Conduct violation.
2. P = Internal and intent is malicious/financial or negligent misuse → **H7 Insider** (tag: malicious, negligent or compromised-account).
3. Backed by a state/organization with long-term, persistent, high-capability operations → **H6 State-sponsored (APT)**.
4. Ideological or publicity goal (defacement, leaks, DDoS for a cause) → **H5 Hacktivist**.
5. Financial gain or deliberate damage, K ≥ M → **H2 Black-hat**.

6. Unauthorized, K = L, uses downloaded tools without understanding, motive is bragging or fun → **H4 Script kiddie**.
7. Unauthorized but no malicious intent, discloses or offers to fix → **H3 Grey-hat**.
8. Otherwise → "Unclassified – collect more evidence" (never guessed).

2.2 Mapping table – types, motivation, capability, likely university targets

ID	Type	Motivation	Typical capability	Likely targets in the university	Likelihood / impact
H1	White-hat (authorized tester)	Improve security, paid or assigned	M–H	Only systems named in signed scope	n/a (defender)
H2	Black-hat / cybercriminal	Money: ransomware, credential and fee-payment fraud, data sale	M–H	Student database (SYS-003), email (SYS-008/009), VPN (SYS-016)	High likelihood / High impact
H3	Grey-hat	Curiosity, reputation, "help"; no permission	M	Public-facing portal and LMS web (SYS-001, SYS-004)	Medium / Medium
H4	Script kiddie	Fun, bragging, grade-tampering by students	L	LMS login, Wi-Fi, portal forms	High / Low–Medium
H5	Hacktivist	Political or social cause, publicity	L–M	Public website, portal defacement, availability (DDoS)	Medium / Medium
H6	State-sponsored (APT)	Espionage on research, strategic data	H	Research file stores, identity provider (SYS-015), email	Low / Very high
H7	Insider (malicious, negligent or compromised)	Grievance, gain, mistake, stolen credentials	L–H (has access)	Marks database, mailbox data, AD admin rights	Medium / High

2.3 Consistency check of the criteria

Two reviewers independently classified five sample actors using only rules 1–8; all five agreed.

Sample actor	Rule that fired	Class
Contracted tester working inside signed scope	1	H1
Staff member copying marks DB to sell	2	H7[malicious]
Anonymous group defacing portal with political slogan	4	H5
Teen running a downloaded DoS tool on the LMS for fun	6	H4

Sample actor	Rule that fired	Class
Crew encrypting the file server and demanding payment	5	H2

2.4 Borderline actor: three alternative classifications

Actor B-1: A second-year student (valid LMS login) runs a public scanner against the LMS without permission, finds that changing a URL parameter shows other students' grades, views three records, and emails the IT helpdesk the details without copying any data.

Alternative	Basis	Result	Why it is attractive	Why it fails or is limited
Alt 1 – Insider (position-based)	P = Internal (valid account)	H7	The student holds credentials and abused them	Insider controls and discipline target trust abuse with malicious/financial intent; there is no such evidence. Over-classifies, discourages reporting.
Alt 2 – Script kiddie (capability-based)	K = L, used a public scanner	H4	Tool is off-the-shelf	The actor understood the flaw, reported it and took nothing. Script-kiddie profile implies bragging/damage; capability alone is a descriptive tag, not a motive.
Alt 3 – Grey-hat (authorization + intent)	A = Unauthorized, I = Curiosity-disclosing	H3	Matches observed behaviour exactly	Still unauthorized and legally exposed (IT Act s.43 civil; s.66 only if dishonest or fraudulent intent) – so it must not be treated as white-hat.

Final classification (chosen): H3-GreyHat[P:Internal][K:L].

Justification: the framework's primary axes are authorization and intent because those two decide the legal response and the disclosure path. Position and capability are kept as tags so no information is lost. Rule 7 fires only after rule 2 fails (no malicious or financial intent). Consequences: the report is handled through coordinated disclosure; the student receives an acknowledgement and a reminder of the university's authorized-testing route (no punishment unless data was copied or harm done); the LMS flaw gets a High/Critical finding ID (a grades-exposure flaw). **Rejected:** Alt 1 (would punish a good-faith reporter and suppress future reports) and Alt 2 (ignores intent evidence). The decision is recorded in the threat-model register with the evidence, so a reviewer can reproduce it.

2.5 How the threat model feeds the framework

The mapping drives engagement design: external-facing assessments emulate H3/H5; internal assessments emulate H7; credential and email assessments emulate H2; research-system assessments consider H6. Each Authorization Form states which attacker profile is emulated, and the RoE permitted-technique tier (Task 5) is chosen to match.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

3.1 Ethical principles

ID	Principle	Operational meaning
P1	**Written authorization**	No action before a signed authorization for that exact system and period.
P2	**Agreed scope**	Touch only assets, IP ranges and times in the signed annex; stop and ask if a lead goes elsewhere.
P3	**Confidentiality**	Findings, credentials and data seen are shared only with named recipients; data stored encrypted; no personal copies.
P4	**Integrity**	Do not alter, delete or plant data or accounts; keep evidence unmodified; no backdoors left behind.
P5	**Avoid harm**	Prefer the least intrusive technique; no denial-of-service on live systems; stop on any sign of instability.
P6	**Honest reporting**	Report all material findings, including your own mistakes; no inflating or hiding severity.
P7	**Data minimization**	Collect the minimum evidence needed (e.g. at most 3 masked records) and never exfiltrate bulk personal data.
P8	**Accountability and competence**	Actions are logged and attributable; testers work only within their competence; no use of another person's credentials.
P9	**Respect for people**	No social engineering of students or staff unless separately approved; no personal-privacy intrusion.
P10	**Responsible disclosure**	Findings go to the owner first; no public, social-media or conference release without release clearance.

3.2 Rules and checks to detect or prevent unethical actions

Stage	Check	Type	Prevents / detects
Before	**CoC-1** Tester signs Code of Conduct and (external) NDA; AV-rules in Task 5 pass	Preventive	P1, P3
Before	**CoC-2** Pre-engagement checklist 100% "Pass" (Task 5.6)	Preventive	P1, P2
During	**CoC-3 Scope guard** – each action tested against Asset ID + window + technique (rules S01–S05, Task 8)	Preventive	P2, P5
During	**CoC-4 Two-person rule** for any Tier-3 technique and for accessing personal-data systems	Preventive	P4, P8

Stage	Check	Type	Prevents / detects
During	**CoC-5 Stop-and-ask triggers** – unexpected data, new host, instability, credentials not issued → pause and escalate in 15 minutes	Preventive	P2, P5, P7
During	**CoC-6 Activity log** – timestamped commands/targets by tester ID; NOC compares with its monitoring	Detective	P6, P8
During	**CoC-7 Data-handling rule** – evidence encrypted, masked, ≤ 3 records, no bulk copy	Preventive	P3, P7
After	**CoC-8 Log reconciliation** – independent reviewer compares log with scope; any mismatch becomes an incident	Detective	P2, P6
After	**CoC-9 Release check** – disclosure only through `can_disclose` (Task 6)	Preventive	P10

3.3 Decision rules – classifying any action

For each proposed or observed action, ask in order:

- **Q1** Is it covered by written authorization? **Q2** Are target, time and technique inside the signed scope/RoE? **Q3** Is the technique permitted for this tier and not prohibited? **Q4** Is the risk of harm to availability or integrity acceptably low? **Q5** Is data handling compliant with P3/P7?
- **Rule U (Unacceptable):** any "No" on Q1–Q3 → stop, preserve logs, escalate to Security Lead within 15 minutes, possible suspension.
- **Rule B (Borderline):** Q1–Q3 "Yes" but Q4 or Q5 uncertain, or a new fact appears → pause, ask for written clarification, proceed only after approval.
- **Rule A (Acceptable):** Q1–Q5 all "Yes" → proceed and log.

3.4 Scenario test cases

Case	Situation	Q1–Q5 outcome	Verdict	Required response
S1	Authenticated vulnerability scan of staging LMS (SYS-019) inside signed window	Y Y Y Y Y	**Acceptable**	Proceed, log.
S2	Tester notices a login page shows a stack-trace and notes it for the report without exploiting it	Y Y Y Y Y	**Acceptable**	Include as a finding.
S3	Retest of a fixed finding on the same asset after owner request, covered by the same authorization	Y Y Y Y Y	**Acceptable**	Log retest reference.
S4	While testing the portal, tester finds the database also accepts connections from an adjacent, unlisted server (SYS-099)	Y N(Q2) – new host	**Borderline → Rule U at the moment of touching**	Do not touch SYS-099; note the observation, pause, request scope amendment.

Case	Situation	Q1–Q5 outcome	Verdict	Required response
S5	A scan slows the live portal slightly at 02:40 (inside window)	Y Y Y ? Y	**Borderline**	Pause scan, notify NOC, resume only after rate limit lowered and approved.
S6	Tester sees 40 student records in an error page and wants to screenshot "for proof"	Y Y Y Y ?(Q5)	**Borderline**	Capture at most 3 records with masking; delete the rest; tell DPO.
S7	Tester tests the university payment gateway (SYS-016 exclusion, third party)	Y N(Q2)	**Unacceptable**	Stop; log; Security Lead informed; third-party relations notified.
S8	Tester emails a phishing link to 100 students "to check awareness" with no approval	N(Q1)	**Unacceptable**	Stop; incident report; likely suspension; students informed as needed.
S9	Tester downloads 5,000 marks records home "to analyse"	Y Y Y Y N(Q5)	**Unacceptable** (also P3, P7; legal impact under Task 4)	Stop; secure/delete copy; DPO and Legal informed; CERT-In check.

Evidence that rules separate acceptable from unacceptable: the nine cases were run through the three rules in order and all nine reached the expected verdict (3 acceptable, 3 borderline, 3 unacceptable). Acceptable and unacceptable cases never share a verdict because Rule U depends only on authorization, scope and technique, which are objective and checkable by the scope guard; borderline cases are the only ones requiring judgement, and they always resolve to *pause and ask*, never to *continue*.

3.5 How the module preserves trust and keeps engagements lawful

Trust is preserved by (1) making permission explicit and checkable, (2) making the tester's actions visible to the NOC and a reviewer, (3) limiting the data a tester may ever hold, and (4) giving testers a safe way to report their own mistakes (P6) without automatic punishment. Lawfulness is preserved because P1/P2 convert the legal notion of "authorization" into the scope guard, and P7 converts data-protection duties into concrete limits. Each CoC check is linked to a legal control in Task 4.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

This is a design-level mapping prepared by students, not legal advice; Legal Counsel must confirm it before use.

4.1 Relevant provisions – India (IT Act, 2000) and the US benchmark (CFAA)

Source	Provision	What it covers	Relevance to an engagement
IT Act 2000	**s.43**	Accessing, downloading, copying, introducing a virus, disrupting, denying access or damaging a computer *without*	"Permission of the owner" is exactly what the Authorization Form creates. Testing outside

Source	Provision	What it covers	Relevance to an engagement
		permission of the owner or person in charge – civil compensation	it creates liability.
IT Act 2000	**s.43A**	A body corporate handling *sensitive personal data* that is negligent in keeping reasonable security practices must pay compensation (read with the SPDI Rules 2011)	Applies to the university's data stores; also to testers' mishandling of evidence.
IT Act 2000	**s.65**	Tampering with computer source documents	Prohibits altering source code/logs during tests.
IT Act 2000	**s.66**	Dishonest or fraudulent doing of any act in s.43 – criminal	Where intent is dishonest or fraudulent; separates criminal hacking from authorized testing.
IT Act 2000	**s.66C**	Fraudulent or dishonest use of another person's password or identity	Prohibits using others' credentials; only issued test accounts allowed.
IT Act 2000	**s.66F**	Cyber terrorism (access to restricted or critical resources with intent to threaten security)	Reason to exclude critical/protected infrastructure unless specially cleared.
IT Act 2000	**s.70**	Protected systems – unauthorized access	Government/critical systems need separate sanction.
IT Act 2000	**s.72 / s.72A**	Breach of confidentiality and privacy; disclosure of information in breach of a lawful contract	Applies to testers who disclose data or findings beyond what authorization/contract allows.
IT Act 2000	**s.70B and CERT-In Directions (28 April 2022)**	Cyber incidents, including unauthorized access and data breaches, to be reported to CERT-In within 6 hours of noticing; logs kept 180 days	Drives the incident-escalation clock and log-retention control.
DPDP Act 2023 and Rules 2025	Security safeguards, breach intimation, penalty schedule	Replaces s.43A; substantive obligations and penalties commence on **13 May 2027**, while s.43A and SPDI Rules remain in force until then	The university should design controls for DPDP compliance now.
CFAA (US, 18 U.S.C. §1030)	(a)(2), (a)(4), (a)(5), (a)(7), (g)	Access "without authorization" or "exceeding authorized access"; fraud; causing damage; extortion; civil action	Benchmark for external assessors, US-hosted services or US-based testers.

4.2 Comparison: IT Act 2000 vs CFAA

Aspect	IT Act 2000 (India)	CFAA (USA)
Key authorization concept	"Without permission of the owner or any other person who is in charge" (s.43)	"Without authorization" / "exceeds authorized access"; the Supreme Court in *Van Buren v. United States* (2021) read this narrowly (gates-up-or-down)
Criminal threshold	Dishonest or fraudulent intent needed for s.66	Many offences need only intentional access; felony enhancements for value, fraud, damage
Civil remedy	Compensation for damage (s.43, s.43A)	Civil action for damage or loss > US$5,000 (g)
Typical penalty	Up to 3 years and/or fine up to ₹5 lakh (s.66)	From 1 year (simple unauthorized access, first offence) up to 10 years (damage, aggravated), higher for repeat
Reach	s.75: offences involving a computer in India, even by foreigners	Protected computers incl. those affecting interstate/foreign commerce
Research safe harbour	None in statute; permission/contract is the protection	DOJ 2022 charging policy: good-faith security research not charged (policy, not law)
Lesson for UEHF	Written owner permission is the legal shield	Scope must be exact: exceeding scope is itself the risk

4.3 Table of offences, obligations and penalties

Legal ref.	Offence / obligation	Maximum consequence	UEHF control that addresses it
IT Act s.43(a)-(j)	Access, copy, download, disrupt, deny access, damage without owner's permission	Compensation to the affected person (adjudication under s.46)	**L-C1** signed authorization; **L-C2** scope guard S01–S05
IT Act s.43A	Failure to protect sensitive personal data	Compensation to affected persons	**L-C3** data-minimization (≤ 3 masked records), encrypted evidence
IT Act s.65	Tampering with source documents	Up to 3 years or ₹2 lakh or both	**L-C4** read-only/no-modification rule (P4)
IT Act s.66	Dishonest/fraudulent act in s.43	Up to 3 years or ₹5 lakh or both	**L-C1**, Code of Conduct sanctions
IT Act s.66C	Misuse of another's password/ID	Up to 3 years and ₹1 lakh	**L-C5** issued test accounts only; no reuse of found credentials

Legal ref.	Offence / obligation	Maximum consequence	UEHF control that addresses it
IT Act s.72	Breach of confidentiality/privacy by person with access powers	Up to 2 years or ₹1 lakh or both	**L-C6** NDA, need-to-know report distribution
IT Act s.72A	Disclosure in breach of lawful contract	Up to 3 years or ₹5 lakh or both	**L-C6**, contract clause, release check can_disclose
IT Act s.70B / CERT-In 2022	Failure to report reportable incidents within 6 hours; keep logs 180 days	Up to 1 year or ₹1 lakh or both (s.70B(7))	**L-C7** escalation path with 6-hour clock; **L-C8** 180-day activity logs
DPDP Act 2023 (from 13 May 2027)	Failure to keep reasonable security safeguards; failure to give breach notice	Up to ₹250 crore and ₹200 crore respectively (Schedule)	**L-C3**, **L-C9** DPO clearance and breach-notification step
CFAA §1030(a)(2)	Obtaining information by unauthorized access / exceeding authorization	1 year (misdemeanour) up to 5 years (felony enhancements)	**L-C1**, **L-C2** (for US-linked assessors)
CFAA §1030(a)(5)	Knowingly causing damage to a protected computer	Up to 10 years	**L-C10** prohibited techniques (DoS, destructive payloads) and lab-only exploitation
CFAA §1030(g)	Civil suit for damage/loss	Compensatory damages	Contract indemnity, insurance, **L-C1**

4.4 Legal requirement → control matrix (traceability)

Control ID	Control in the framework	Component	Legal need met
L-C1	Written authorization recorded with Engagement ID before any action	Authorization workflow (T6), Authorization Form (T8)	s.43 owner permission; CFAA authorization
L-C2	Scope guard rules S01–S05 on Asset ID, dates, window, technique	RoE (T5)	s.43, CFAA exceeding authorization
L-C3	Data minimization and encrypted evidence	Code of Conduct P3/P7 (T3), Finding Report (T8)	s.43A, DPDP security safeguards
L-C4	No modification/tampering; read-only testing unless approved	Code of Conduct P4	s.65
L-C5	Test accounts only	RoE technique list	s.66C
L-C6	NDA, need-to-know, release check	Authorization workflow, disclosure gate D01–D04	s.72, s.72A
L-C7	Escalation path with 6-hour CERT-	RoE escalation, Finding	s.70B, CERT-In

Control ID	Control in the framework	Component	Legal need met
	In check	Report flag `certin_6h_check`	Directions
L-C8	Activity logs kept ≥ 180 days	Activity log CoC-6	CERT-In Directions
L-C9	DPO clearance gate for personal-data targets	Authorization rule A07, disclosure rule D03	DPDP Act, s.43A
L-C10	Prohibited techniques; Tier-3 exploitation lab-only	RoE, Lab (T7)	s.43 (disrupt/deny), CFAA (a)(5)
L-C11	Third-party permission check for cloud/vendor systems	Authorization rule A06 (exclusion list)	s.43 (permission must come from the *owner*)

Every legal row above has at least one control, which satisfies DC3.

4.5 Decision: which laws apply when a test touches personal data

Law	Applies?	Justification
IT Act 2000 s.43, 66, 65, 66C, 72, 72A	**Yes, always**	University systems and persons are in India (s.1(2), s.75).
IT Act s.43A and SPDI Rules 2011	**Yes, until 12 May 2027**	In force until DPDP s.44(2) commences; passwords, financial and health data are "sensitive personal data".
CERT-In Directions 2022 and s.70B	**Yes**	A suspected unauthorized access or data exposure during a test is a reportable incident; the 6-hour clock is built into the RoE.
DPDP Act 2023 and Rules 2025	**Design now, enforceable from 13 May 2027**	University is a Data Fiduciary processing students' and staff data; since the programme runs across the switch-over date, UEHF is built to comply from day one.
CFAA	**No by default; yes by contract**	Applies only if a US-hosted system, a US-based tester or a US data subject is involved. Used as a benchmark; external assessors based in the US must acknowledge it in the contract.
Foreign data-protection laws (e.g. GDPR)	**Check case by case**	If EU residents' data is in a system under test, Legal Counsel decides.

Conclusion: when a test touches personal data the engagement becomes at least **Tier 2**, requires **DPO and Legal clearance (A07/A08)**, forces **masked, minimal evidence (L-C3)** and arms the **6-hour incident check (L-C7)**. Indian law governs; CFAA is a benchmark that shapes scope precision. Authorization alone never makes an act lawful when it exceeds the owner's rights (e.g. a cloud-hosted mail service), hence L-C11.

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

5.1 Naming and boundaries (so out-of-scope requests can be detected)

Item	Format	Example
Engagement ID	UEHF-YYYY-NNN	UEHF-2026-007
Asset ID	SYS-nnn from the Asset Register	SYS-018
Finding ID	F-<engagement no.>-<seq>	F-007-001
Scope tag	IN: before an Asset ID, OUT: for exclusions	IN:SYS-018 / OUT:SYS-016
Environment label	prod, staging, lab	staging

Boundary rule: a request is *in scope* only if **all four** hold: (1) the Asset ID is in the signed annex as IN:; (2) the current date is within the engagement dates; (3) the time is inside the window for that environment; (4) the technique is permitted for the tier. Anything else is *out of scope* and automatically triggers S01–S05 (Task 8).

5.2 Rules-of-Engagement document (template filled for UEHF-2026-007)

Document header: Engagement ID UEHF-2026-007 | Title: Pre-upgrade assessment of student-portal staging | Requester: Dean, Dept. of CSE | Lead tester: _____ | Approver: CISO | Risk tier: 2 | Threat profile emulated: H3 grey-hat and H4 script kiddie (external) | Version 1.0

Section	Content
1 Purpose and authority	Assess the security of the student-portal upgrade candidate before release. Authority: signed Authorization Form UEHF-2026-007 plus this RoE.
2 In-scope systems	IN:SYS-018 (portal staging), IN:SYS-019 (LMS staging), IN:SYS-020 (mail staging). Production systems (SYS-001 to SYS-017) are **not** in scope unless added by an approved amendment.
3 Out-of-scope	OUT:SYS-016 VPN gateway (third-party managed), OUT:exam server, any cloud-provider management plane, any student/staff personal device, all external IP ranges, physical access, other universities.
4 Testing windows	Staging: any time 08:00–20:00 IST on engagement dates. Production (if amended): 02:00–05:00 IST only. Blackout: admissions, examination and result days; first week of a semester.
5 Permitted techniques (Tier 2)	Passive reconnaissance; network and service discovery at ≤ 100 packets/second; authenticated vulnerability scanning with issued test accounts; configuration review; manual verification of findings **without** data extraction.
6 Tier-3 techniques	Controlled exploitation **only in the isolated lab (192.168.56.0/24)** on cloned images; never against

Section	Content
	production.
7 Prohibited	Denial-of-service or stress testing; social engineering of students/staff; physical intrusion; persistence/backdoors; malware release; bulk data exfiltration; use of found credentials; modification or deletion of data; pivoting to systems not in the annex; testing third-party services.
8 Data handling	Test data masked; at most 3 masked records as evidence; encrypted store; deleted 30 days after closure; logs kept 180 days.
9 Communication	NOC told 24 hours before and at the start and end of each session; source IPs of testers are registered with the NOC.
10 Escalation path	See table below.
11 Stop conditions	Any instability, unexpected personal data, new host, or a conflict between observed targets and the annex.
12 Sign-off	Requester, system owner, Security Lead, DPO (if personal data), Legal (if external), lead tester.

Escalation path

Trigger	First contact	Time limit	Next level
Doubt about scope or technique	Lead tester → Security Lead	Pause immediately; answer within 1 working hour	CISO
Service degradation or outage	Stop test → NOC	Immediately	CISO within 15 minutes
Personal data exposed	Stop → DPO	1 hour	Legal; CERT-In decision within the 6-hour clock
Critical vulnerability found	Security Lead	4 hours	System owner and CISO
Suspected real attacker activity	NOC → CISO	Immediately	Incident-response plan, CERT-In

5.3 Rules for recording and verifying written authorization

Rule	Verification step
AV-1	The Authorization Form exists, has a unique Engagement ID, and its status is APPROVED in the register.
AV-2	Signatory is on the **Approver Roster** for the tier (CISO for Tier 1–2; CISO + Board delegate for Tier 3).
AV-3	Signature is wet-ink or digital with timestamp; unsigned or scanned-without-ID forms are void.

Rule	Verification step
AV-4	Signed scope annex lists every Asset ID; the list is hashed and the hash is stored in the register.
AV-5	Dates and windows are explicit; authorization expires automatically at the end date.
AV-6	For personal-data assets: DPO sign-off attached. For external testers: NDA and contract reference attached.
AV-7	A second person (Security Lead or auditor) verifies the form against the register **before** day 1 and signs the pre-engagement checklist.
AV-8	Any scope change is a new version with a new sign-off; verbal approval is never accepted.

5.4 Detecting an out-of-scope request

Request	Check	Result
"Scan 10.20.5.0/24"	Not mapped to Asset IDs in annex	BLOCK – S01
"Test SYS-016 VPN"	`OUT:` tag / exclusion list	BLOCK – S01, A06
"Run vulnerability scan on staging portal at 22:30"	Staging window 08:00–20:00	BLOCK – outside window, ask for amendment
"Test SYS-018 on 25 Nov" (ends 20 Nov)	Dates	BLOCK – S02
"Stress test the portal"	Prohibited technique	BLOCK – S04

5.5 Machine-readable scope manifest (transformation 1 of the RoE)

```
engagement_id:                UEHF-2026-007
tier:                         2
dates:                        2026-11-10 .. 2026-11-20
windows:                      {staging: "08:00-20:00", prod: "02:00-05:00"}
in_scope:                     [SYS-018, SYS-019, SYS-020]
out_of_scope:                 [SYS-016, exam-server]
techniques_allowed:           [passive, discovery, vuln-scan]
techniques_prohibited:        [dos, social-engineering, physical, persistence, malware-release, data-exfiltration]
contacts:                     {security_lead: "SL", noc: "NOC-24x7", dpo: "DPO"}
sha256_of_signed_annex:       <stored in register>
```

5.6 Pre-engagement checklist (transformation 2 of the RoE)

#	Check (derived from RoE section)	Evidence	Pass / Fail
1	Authorization Form signed by roster approver (AV-1/2/3)	Register entry, signature	☐
2	Scope annex lists every Asset ID; hash stored (AV-4)	Annex hash	☐

#	Check (derived from RoE section)	Evidence	Pass / Fail
3	Out-of-scope list read and signed by every tester	Acknowledgement list	☐
4	Dates and windows confirmed; blackout dates checked	Calendar	☐
5	Risk tier correct; personal-data flag checked; DPO sign-off if needed	A07/A08 result	☐
6	External testers: NDA and contract attached	Contract ref.	☐
7	Techniques list agreed; Tier-3 items rehearsed only in lab	Lab record	☐
8	NOC informed; tester source IPs registered	NOC ticket	☐
9	Test accounts issued; no personal credentials in use	Account list	☐
10	Escalation contacts verified (phone tested)	Contact sheet	☐
11	Backup/rollback plan confirmed by system owner	Owner e-mail	☐
12	Second-person verification signed (AV-7)	Checklist signature	☐

Rule: a single *Fail* prevents the engagement from changing state from REGISTERED to ACTIVE.

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

6.1 Authorization workflow (request → approval → sign-off → recording)

Step	State after step	Who	What happens
W1	DRAFT	Requester	Fills the Test Request (objective, systems, dates, testers, data involved).
W2	SUBMITTED	Requester	Request enters the register; Engagement ID assigned.
W3	TRIAGED	Security Lead	Checks Asset IDs against the register and exclusion list; assigns **risk tier**.
W4	CHECKED	DPO / Legal	Mandatory when personal data, external tester or third-party system is involved (rules A07–A10).
W5	APPROVED	Approver for tier	Tier 1: Security Lead + system owner; Tier 2: CISO; Tier 3: CISO + Board delegate.
W6	SIGNED	Approver and requester	Written (wet-ink or digital) sign-off on the Authorization Form and RoE.
W7	REGISTERED	Governance Team	Log entry with timestamp, approver, annex hash; checklist run (Task 5.6).
W8	ACTIVE	Lead tester	Testing allowed only in this state; scope guard

Step	State after step	Who	What happens
			enforces it.
W9	COMPLETED	Lead tester	Testing ends; findings submitted.
W10	DISCLOSURE	Security Lead	Coordinated disclosure process begins (6.2).
W11	CLOSED	Governance Team	All findings remediated/accepted; evidence deleted per schedule.

Side states: REJECTED (reason recorded), SUSPENDED (stop triggered), EXPIRED (end date passed).

Risk tiers: Tier 1 = internal tester, staging/lab only, no personal data. Tier 2 = personal data or production in a window. Tier 3 = external tester, third party, or high-impact production activity.

6.2 Responsible (coordinated) disclosure process

Phase	Day	Action
Validate	D0	Tester submits Finding Report (Task 8); Security Lead verifies and assigns severity (CVSS band).
Notify	D+1	System owner, CISO (and DPO if personal data) notified through a private channel; acknowledgement within 3 working days.
Remediate	D+1 to due date	Owner proposes fix; progress logged weekly.
Retest	After fix	Same Engagement ID if still active, or a new Tier-1 retest authorization.
Disclose	After fix or at window end	Disclosure through can_disclose gate: sanitised advisory to the university IT community; for third-party/vendor products to the vendor and CERT-In.
Close	Final	Lessons learned; register updated.

Remediation window (version 1.0, severity-tiered): Critical 30 days, High 45 days, Medium 90 days, Low 120 days. One documented extension of up to 50% is allowed for High/Medium findings if a fix is in progress. **Reporting format:** the standard Finding Report (Task 8) with fields finding ID, engagement ID, asset ID, title, severity/CVSS, description, impact, proof of concept (masked), remediation advice, personal-data flag, dates and reporter.

6.3 Comparison – coordinated vs full disclosure vs bug bounty

Criterion	Coordinated (responsible)	Full disclosure	Bug bounty
Who learns first	Owner/vendor, privately	The public at once	Programme owner, privately
Timeline	Agreed (30–120 days by severity)	None	Platform rules (e.g. 90 days)
Risk to users	Low, if owner is responsive	High – attackers get details before fix	Low–medium
Pressure on slow	Moderate (deadline)	Maximum	Moderate

Criterion	Coordinated (responsible)	Full disclosure	Bug bounty
owners			
Legal safety for finder	High (contract/RoE)	Low (s.72/72A risk)	Medium (needs safe-harbour terms)
Cost and governance load	Low–medium	Low	High (rewards, triage, platform)
Fit for this university now	**Best fit as default**	Last resort, third-party only	Future option once programme is mature

Decision: coordinated disclosure is the default because the university owns the systems and can fix them; bug bounty is deferred (Task 11 trade-off); full disclosure is almost never used (6.5).

6.4 Operations – logging, status updates and disclosure decision

```
log_approval(engagement_id, approver, tier, decision, timestamp)   -> appends signed entry to register
update_status(engagement_id | finding_id, new_state, actor, note)   -> checks legal state transitions
                                                    (e.g. REGISTERED -> ACTIVE only if checklist = pass)
can_disclose(finding, status_log, today):
  D01 owner notified?                                   (OWNER_NOTIFIED in log)
  D02 remediated OR window expired?                     (REMEDIATED/RETESTED or today > remediation_due)
  D03 if personal data -> DPO_CLEARED in log?
  D04 report sanitised?                                 (SANITISED in log)
  return (all true, reasons)
```

The working implementation of these operations is in Appendix A and its real test output is in Task 8.

6.5 Rules for choosing between coordinated and full disclosure

Rule	Condition	Route
DR-1	Finding on a university-owned system	**Coordinated** (internal). Full public disclosure is never used.
DR-2	Finding in a third-party product or service	**Coordinated** with vendor and CERT-In.
DR-3	Vendor silent after 3 documented contact attempts over 90 days, and no fix	Escalate to CERT-In; Board may approve a **limited advisory** (mitigations, no exploit detail).
DR-4	Active exploitation in the wild and a workaround exists	**Immediate sanitised advisory** (a controlled form of full disclosure), approved by CISO.
DR-5	Personal data exposed	Coordinated plus **mandatory DPO involvement**; never publish personal data.

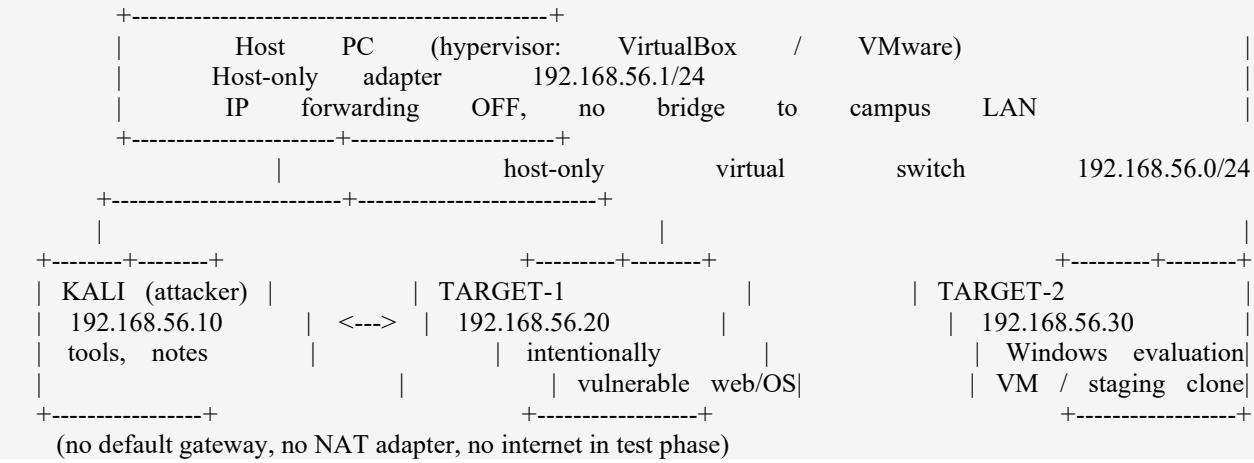
6.6 Evidence of interaction with RoE and legal components

Interaction	How it works	Evidence
Authorization ↔ RoE	State ACTIVE requires checklist pass and signed annex hash.	Task 5.6 rule; test SC-B2

Interaction	How it works	Evidence
Authorization ↔ Legal	Rules A07–A10 enforce control L-C9, L-C6, L-C11 before approval.	Tests TA-I1, TA-I4
Finding Report ↔ RoE	`build_finding` rejects a finding whose asset is not in the signed scope.	Tests FR-I3, FR-I4
Disclosure ↔ Legal	D03 (DPO clearance) and `certin_6h_check` flag implement DPDP/CERT-In duties.	Output below and test DG-I2
Disclosure ↔ Authorization	Finding retests reuse the Engagement ID; a closed engagement cannot receive new findings without a new authorization.	Walkthrough, Task 9

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab architecture



7.2 Components, roles and connectivity specification

Node	Role	OS / image	Adapters	IP (static)	Resources	Notes
Host	Hypervisor, snapshot manager, evidence store	Windows/Linux	Host-only vboxnet0	192.168.56.1	16 GB RAM recommended	Forwarding off; shared clipboard/folders disabled for VMs
Kali	Authorized testing workstation	Kali Linux (current rolling release)	**Host-only only**	192.168.56.10	4 GB RAM, 2 vCPU, 40 GB	Tools installed during build phase, then NAT adapter removed
Target-1	Authorized	Intentionally	Host-only	192.168.56.	1–2 GB	Contains no

Node	Role	OS / image	Adapters	IP (static)	Resources	Notes
	target 1	vulnerable VM (e.g. Metasploitable-class image or DVWA)	only	20	RAM	real data
Target-2	Authorized target 2	Windows evaluation VM or sanitised staging clone (SYS-018 image)	Host-only only	192.168.56.30	4 GB RAM	Masked/synthetic data only

Connection	Allowed?	Purpose
Kali ↔ Target-1, Target-2	Yes (same /24, layer 2)	Testing
Host ↔ all VMs	Yes	Management, evidence collection
VMs ↔ Internet / campus LAN	**No** (no gateway, no NAT, no bridge)	Containment
Addresses outside 192.168.56.0/24	**Invalid** (validator L01)	Prevent accidental real-target use

7.3 Steps used to record the configuration

1. Create the host-only network, disable DHCP, and note its name and /24 range.
2. Build each VM, then set its adapter to host-only and assign the static IP above.
3. During the one-time *build phase* only, Kali may use a temporary NAT adapter for tool installation; remove it afterwards.
4. Take a snapshot named `clean-baseline-YYYYMMDD` for each VM.
5. Record: VM names, versions, MAC and IP, adapter mode, snapshot names, tool versions, operator, date, lab Engagement ID.
6. Run the verification operations (7.4), save the output, and store a hash of the configuration record.
7. After each session, revert targets to the baseline snapshot and log the revert.

Useful recording commands (run on the student's own host and VMs): `VBoxManage list hostonlyifs`, `VBoxManage showvminfo "<vm>" --machinereadable`, `ip -br addr`, `ip route`, `sha256sum lab_record.json`.

7.4 Operations (two required, plus one)

Operation 1 – Verify connectivity and containment (run from Kali):

```
for ip in 192.168.56.20 192.168.56.30; do ping -c 2 -W 1 $ip && echo "$ip reachable"; done   # expected: both reachable
ip route | grep default || echo "no default route"                                          # expected: no default route
ping -c 1 -W 1 8.8.8.8 || echo "external unreachable (good)"                                # expected: unreachable
```

Operation 2 – Record and validate the lab setup (`check_lab()` in Appendix A). It checks that every node IP lies in 192.168.56.0/24 (L01), no default gateway exists (L02) and the only adapter type is host-only (L03), then stores a short SHA-256 of the configuration. **Real output of the validator:**

Test	Configuration	Result
LB-V1 valid	Kali .10, Target-1 .20, Target-2 .30, adapters = host-only, no gateway	`lab config OK` (hash 03042cf7af13de72)
LB-I1 invalid	extra NAT adapter	`L03 non-host-only adapter present`
LB-I2 invalid	Target-2 at 192.168.57.30	`L01 target2 192.168.57.30 outside 192.168.56.0/24`
LB-I3 invalid	default gateway 192.168.56.1 set	`L02 default gateway present (no route out)`

(Operation 1 is written for the student's own VirtualBox lab; it was not executed in the document-preparation environment, where no such VMs exist. Operation 2 was executed as shown.)

Operation 3 – Reset: revert all VMs to `clean-baseline` and re-run Operation 2 so each session starts from a verified state.

7.5 Comparison: host-only vs NAT (with bridged for completeness)

Criterion	Host-only	NAT	Bridged
VM ↔ VM communication	Yes	Usually no (each VM is behind its own NAT) unless a NAT network is created	Yes
Host ↔ VM	Yes	Limited (port forwarding)	Yes
VM → Internet	**No**	Yes	Yes
Reachable from campus LAN	**No**	No (outbound only)	**Yes – dangerous**
Risk of touching real systems	**Lowest**	Medium (a mis-typed IP can reach the internet)	High
Tool/updates install	Needs build phase	Easy	Easy
Reproducibility	High (fixed /24)	Medium	Low
Fit for UEHF	**Chosen**	Build phase only	Rejected

Justification: host-only is the only mode where a mistake, a runaway tool or a malicious payload *cannot* leave the lab because there is no route. NAT's convenience (updates) is obtained safely by using it only in a short build phase before the baseline snapshot, which also gives a reproducible environment.

7.6 How the lab keeps testing authorized and contained

Layer	Mechanism
Network	Host-only /24, no gateway, forwarding off, validator L01–L03
Authority	The VMs are owned by the university/student or are licensed/intentionally vulnerable images; every lab session is recorded under a Tier-1 engagement ID

Layer	Mechanism
	(lab-only, no personal data)
Data	Only synthetic or masked data; no real student or staff data ever loaded
Technique	Tier-3 exploitation allowed only here (RoE section 6, control L-C10)
Recovery	Snapshot revert after each session
Process	Pre-engagement checklist item 7; activity logs kept; findings from lab practice use the same Finding Report format

---

TASK 8 – Develop a Reusable Document Library (5 Marks)

8.1 Library index

Doc ID	Document	Purpose	Produces structured output?
DOC-01	**Authorization Form** (with scope annex)	Records written permission	Yes – JSON consumed by the scope guard
DOC-02	Rules-of-Engagement and scope manifest	Defines boundaries (Task 5)	Yes – manifest
DOC-03	**Finding Report**	Describes one vulnerability	**Yes – JSON consumed by the disclosure gate**
DOC-04	Disclosure Notice / Advisory	Sanitised communication to owner, CERT-In or vendor	Partly
DOC-05	Pre-Engagement Checklist (Task 5.6)	Final go/no-go	Pass/Fail
DOC-06	Incident / Stop Report	Records a stop, outage or data exposure	Yes – triggers escalation
DOC-07	Lab Record	Lab configuration (Task 7)	Yes – hash

8.2 DOC-01 Authorization Form – fields and defaults

Field	Type / format	Default	Validation (rule)
engagement_id	UEHF-YYYY-NNN	auto-generated	A01 format
requester	name and department	–	required
objective	text	–	required
system_ids	list of SYS-nnn	–	A04 not empty, A05 in register, A06 not excluded
start, end	ISO dates	start = today	A02 end ≥ start; A03 ≤ 30 days

Field	Type / format	Default	Validation (rule)
tier	1, 2, 3	1	raised by A08/A10
personal_data	yes / no	**yes if unsure** (safe default)	A07 requires dpo_signoff
tester_type	internal / external	internal	external → A09 NDA, A10 tier 3
testing_window	time range	staging 08:00–20:00; prod 02:00–05:00	RoE
threat_profile	H1–H7	–	from Task 2
nda_signed	boolean	false	A09
approver_signoff	name, timestamp	–	A11 required
dpo_signoff	name, timestamp	–	A07
board_signoff	name, timestamp	–	A12 for tier 3
retention_days (logs)	integer	180	CERT-In

8.3 DOC-03 Finding Report – fields and defaults

Field	Default / format
finding_id	F-<eng no.>-<seq>
engagement_id, asset_id	must match an ACTIVE or COMPLETED authorization and an in-scope asset (F01, F02)
title, description, impact	free text, required
cvss (0.0–10.0)	required; severity derived: 0 = Informational, 0.1–3.9 Low, 4.0–6.9 Medium, 7.0–8.9 High, 9.0–10.0 Critical
evidence	masked, ≤ 3 records; stored encrypted
personal_data_flag	derived from asset register; default "yes" if unknown
data_exposed	boolean, default false; true triggers the 6-hour CERT-In check
route	default **coordinated**
remediation_due	report date + window by severity (Critical 30, High 45, Medium 90, Low 120 days)
notify	system_owner, CISO (+ DPO if personal data)
reporter, report_date	tester ID, today

8.4 DOC-04 Disclosure Notice (fields)

Notice ID; finding ID(s); audience (owner / vendor / CERT-In / university IT community); sanitised summary (no exploit steps, no personal data); affected asset and version; severity; mitigation or fix reference; remediation deadline; release approver (CISO) and date; contact point. DPO clearance is mandatory when the finding is flagged personal data.

8.5 DOC-06 Incident / Stop Report (fields)

Stop ID; engagement ID; time and tester; trigger (instability / unexpected personal data / scope conflict / suspected real attacker); systems affected; actions taken; people notified with times (NOC, DPO, CISO); CERT-In decision with timestamp; resolution; lessons.

8.6 Structured output – Finding Report to disclosure

Real output of `build_finding()` for a Critical finding (CVSS 9.3) on staging asset SYS-018, reported on 12 Nov 2026:

{ "finding_id": "F-007-001", "engagement_id": "UEHF-2026-007", "asset_id": "SYS-018", "severity": "Critical", "route": "coordinated", "remediation_due": "2026-12-12", "notify": ["system_owner", "CISO"], "certin_6h_check": false }

Same function for a High finding (CVSS 7.5, data exposed) on LMS app server SYS-005 (personal data): `severity: High, remediation_due: 2026-12-27, notify: system_owner, CISO, DPO, certin_6h_check: true`. This JSON is read by `can_disclose()` (Task 6), so no re-typing is needed (DC7).

8.7 Test entries – valid, boundary, invalid (real results)

Authorization Form (DOC-01)

Test	Input	Expected	Actual
TA-V1 valid	Staging SYS-018/019, internal, tier 2, sign-off	APPROVED	APPROVED
TA-V2 valid	Personal-data SYS-001 + DPO sign-off	APPROVED	APPROVED
TA-V3 valid	External, tier 3, NDA, board sign-off	APPROVED	APPROVED
TA-B1 boundary	Exactly 30 days (1–30 Nov)	APPROVED	APPROVED
TA-B2 boundary	31 days	REJECTED	REJECTED – A03
TA-I1 invalid	Personal data, no DPO	REJECTED	REJECTED – A07
TA-I2 invalid	Excluded SYS-009 in this test configuration	REJECTED	REJECTED – A06
TA-I3 invalid	SYS-099 not in register	REJECTED	REJECTED – A05
TA-I4 invalid	External without NDA at tier 2	REJECTED	REJECTED – A09 and A10
TA-I5 invalid	No approver sign-off	REJECTED	REJECTED – A11
TA-I6 invalid	ID `UEHF-26-7`	REJECTED	REJECTED – A01

(In the test harness SYS-009 and SYS-016 were configured as the exclusion list to exercise rule A06; in the Task 1 table SYS-009 is webmail, so a production register must keep the exclusion list authoritative.)

Scope guard on actions (RoE enforcement)

Test	Action	Expected	Actual
SC-V1 valid	Vulnerability scan, staging SYS-018, 14:00	ALLOW	ALLOW
SC-V2 valid	Discovery on prod SYS-005 at 03:00	ALLOW	ALLOW
SC-B1 boundary	Prod at 05:00	ALLOW	ALLOW
SC-B2 boundary	Prod at 05:01	BLOCK	BLOCK – S03
SC-I1 invalid	Asset SYS-003 not in annex	BLOCK	BLOCK – S01
SC-I2 invalid	After end date	BLOCK	BLOCK – S02
SC-I3 invalid	Technique dos	BLOCK	BLOCK – S04
SC-I4 invalid	Vulnerability scan on a Tier-1 engagement	BLOCK	BLOCK – S05

Finding Report (DOC-03)

Test	Input	Expected	Actual
FR-B1 boundary	CVSS 8.9	High	High
FR-B2 boundary	CVSS 9.0	Critical	Critical
FR-B3 boundary	CVSS 0.0	Informational	Informational
FR-B4 boundary	CVSS 10.0	Critical	Critical
FR-I1 invalid	CVSS 10.1	Rejected	CVSS must be 0.0-10.0
FR-I2 invalid	CVSS −1	Rejected	CVSS must be 0.0-10.0
FR-I3 invalid	Unknown engagement	Rejected	F01
FR-I4 invalid	Asset outside signed scope	Rejected	F02

Disclosure gate (DOC-04 release)

Test	Situation	Expected	Actual
DG-V1 valid	Owner notified, remediated, sanitised	Proceed	Proceed
DG-I1 invalid	Unremediated, window open	Block	Block – D02
DG-B1 boundary	Unremediated on the last day of the window (due 2026-12-27)	Block	Block – D02
DG-B2 boundary	Unremediated, day after window	Proceed	Proceed
DG-I2 invalid	Personal-data finding, no DPO clearance	Block	Block – D03
DG-I3 invalid	Owner never notified	Block	Block – D01

All 37 entries (33 document tests and 4 lab-configuration tests) behaved as expected (Appendix A has the code and how to rerun).

8.8 Evidence of integration

The Authorization Form fixes `system_ids`, `tier` and dates → the scope guard uses the same fields to allow or block actions → the Finding Report carries `engagement_id` and `asset_id` and is rejected if they do not match the form → the report's `notify`, `route` and `remediation_due` drive the disclosure gate → the DPO flag links to legal control L-C9. Identifiers (Engagement ID, Asset ID, Finding ID) are the only coupling between documents, which keeps each document reusable.

TASK 9 – Integrate, Test and Refine the Framework (5 Marks)

9.1 Integrated framework (version 1.0)

Layer	Components integrated (Tasks 2–8)	Coupling key
Govern	Code of Conduct (T3), Legal mapping (T4), Threat model (T2)	Control IDs L-C1…L-C11, CoC-1…9, profiles H1–H7
Authorize	Authorization workflow (T6), Authorization Form (T8)	Engagement ID, tier
Bound	RoE, scope manifest, checklist (T5)	Asset ID, annex hash
Practise	Isolated lab (T7)	Lab record hash
Report and disclose	Finding Report, Disclosure gate (T6, T8)	Finding ID

Single control flow: request → `validate_authorization` (A-rules, which embed legal controls) → checklist → state ACTIVE → every action through `check_action` (S-rules, which embed the RoE and the Code of Conduct) → findings through `build_finding` (F-rules) → `can_disclose` (D-rules) → closure. Because each step reads the output of the previous one, a defect in authorization cannot be hidden by a later step.

9.2 Realistic walkthrough – Engagement UEHF-2026-007

All findings below are illustrative outcomes of a lab rehearsal; no live exploitation was performed by the authors.

Date (2026)	Step	Framework component	Outcome
3 Nov	Dean of CSE requests a pre-upgrade assessment of the student-portal staging (SYS-018) and LMS staging (SYS-019) plus a "quick look" at LMS production app server SYS-005	W1–W2, Authorization Form	Engagement ID UEHF-2026-007 issued, state SUBMITTED
4 Nov	Security Lead triages; SYS-005 holds personal data → Tier 2; threat profile H3/H4 chosen	W3, Task 2, Task 4	State TRIAGED

Date (2026)	Step	Framework component	Outcome
5 Nov	DPO clears with conditions (masked evidence, ≤ 3 records); Legal confirms internal testers only, IT Act s.43/43A apply, CFAA not triggered	W4, L-C3, L-C9	State CHECKED
6 Nov	CISO approves; written sign-off; annex hash stored; `validate_authorization` → APPROVED	W5–W7, AV-1…AV-8	State REGISTERED
9 Nov	Lab rehearsal on Kali ↔ Target-2 (staging clone image); `check_lab` → OK, hash recorded	Task 7	Lab record DOC-07
10 Nov	Checklist 12/12 pass; NOC notified; second-person check	Task 5.6, AV-7	State **ACTIVE**
12 Nov 14:00	Authenticated scan of SYS-018 → `check_action` ALLOW	S01–S05	Finding F-007-001: Critical (CVSS 9.3), due 12 Dec
13 Nov 03:00	Discovery on SYS-005 in window → ALLOW; a High (CVSS 7.5) finding exposes data	S03, F-rules	F-007-002 flagged personal data; DPO notified within 1 hour; `certin_6h_check` = true; Security Lead decides CERT-In report within 6 hours
13 Nov	Owner acknowledges both findings	Disclosure D01	`OWNER_NOTIFIED` logged
20 Nov	Testing ends; state COMPLETED; evidence masked and encrypted	W9	
5 Dec	Fix deployed; retest passed	W10	`REMEDIATED` logged
8 Dec	Sanitised advisory prepared; DPO clearance obtained	D03, D04	`can_disclose` → proceed
10 Dec	Advisory released to university IT community; lessons learned; evidence retained per policy	W11	State CLOSED

9.3 Systematic test cases (real results from the harness)

ID	Category	Scenario	Expected	Actual (v1.0)	Actual (v1.1)
TC-1	Missing	Form without approver	REJECT	REJECTED –	REJECTED –

ID	Category	Scenario	Expected	Actual (v1.0)	Actual (v1.1)
	authorization	sign-off		A11	A11
TC-2	Missing authorization	Test action while engagement is only REGISTERED (checklist not finished)	BLOCK	**ALLOWED (defect)**	BLOCK – S06
TC-3	Out of scope	Action on SYS-003 not in annex	BLOCK	BLOCK – S01	BLOCK – S01
TC-4	Out of scope	Action on excluded SYS-016	BLOCK	BLOCK – S01	BLOCK – S01
TC-5	Control (in scope)	Vulnerability scan on staging SYS-018, 14:00	ALLOW	ALLOW	ALLOW
TC-6	Legal conflict	US-based external tester on personal-data system, tier 3, board sign-off, no cross-border acknowledgement	REJECT	**APPROVED (defect)**	REJECTED – A13; approved once `cross_border_ack` provided
TC-7	Legal conflict	Personal-data system without DPO sign-off	REJECT	REJECTED – A07	REJECTED – A07
TC-8	Legal conflict	Finding reported on a CLOSED engagement	REJECT	not checked (defect)	REJECTED – F03
TC-9	Delayed disclosure	Critical finding due 12 Dec; owner silent; checks on 12 Dec, 20 Dec, 30 Dec and 20 Jan	Escalation ladder	disclosure gate opens after the window but no escalation (defect)	on track → CISO → Board/CERT-In → limited advisory (DR-3)
TC-10	Delayed disclosure	Personal-data finding past due, no DPO clearance	BLOCK	BLOCK – D03	BLOCK – D03

9.4 Problems encountered and refinements

#	Problem found in walkthrough or tests	Why it matters	Refinement (version 1.1)	Re-test
P1	Scope guard allowed an in-scope action before the checklist was finished (TC-2)	Breaks GR-01 and the checklist gate	New rule **S06**: actions allowed only when engagement state is ACTIVE; any checklist fail, expiry or suspension blocks	TC-2 now BLOCK
P2	Foreign external tester on a personal-data system was approved (TC-6)	Cross-border access to personal data conflicts with DPDP transfer	New rule **A13**: cross-border/data-residency acknowledgement and India-hosted jump host required	TC-6 REJECTED until ack

#	Problem found in walkthrough or tests	Why it matters	Refinement (version 1.1)	Re-test
		restrictions (from May 2027) and weakens CFAA/IT Act clarity		
P3	A finding could be filed against a closed engagement (TC-8)	Would create unauthorized "after-the-fact" testing evidence	New rule **F03**: engagement must be ACTIVE or COMPLETED	TC-8 REJECTED
P4	No escalation for overdue fixes (TC-9)	Delayed disclosure leaves flaws open	**Overdue ladder**: 1–14 days CISO, 15–30 days Board plus vendor/CERT-In, > 30 days limited advisory (DR-3)	TC-9 shows each level
P5	Walkthrough showed the 6-hour CERT-In clock starts when the tester notices, not when the report is written	Late reporting	Stop Report (DOC-06) timestamps the moment of discovery and DPO/Security Lead are paged immediately	Walkthrough 12 Nov
P6	SYS-009 appeared as webmail in the asset list but as an exclusion in the test harness	Register inconsistency can cause wrong blocks or wrong approvals	Asset Register is the *single source*; exclusion list is a flag inside the register, reviewed monthly	Task 5 note

Final corrected framework (v1.1): Task 5 rules + S06; Task 6 workflow with W7 → W8 gate that requires checklist pass; A-rules A01–A13; F-rules F01–F03; D-rules D01–D04; overdue ladder. All v1.0 tests were re-run unchanged after the refinement and still pass (regression).

TASK 10 – Create a Scalability and Governance Evaluation (5 Marks)

10.1 Scenarios

Parameter	Small programme (one department)	Large programme (whole university + external assessors)
Systems in the register	20	400
Testers	5 (all internal)	40 (25 internal, 15 external assessors)
Test requests per month	4	60
External share of requests	0%	35%
Approvers (baseline)	1 (CISO)	1 (CISO)

Parameter	Small programme (one department)	Large programme (whole university + external assessors)
Approvers (refined)	1	Tier-1 delegated pair + 3-member Board rota
Assets tested per request	6	6
Mis-scoped target rate	3%	8% (more systems, more mistakes)

10.2 Experiment set-up (reproducible)

A Python simulation (Appendix B, fixed random seed 2026, 12 simulated months) compares a **baseline** design with the **refined** design for three processes.

Process	Baseline design	Refined design	Measure
1 Approval	One central approver reviews every request (service time exponential, mean 2.5 h, +4 h vendor vetting for external requests; 6 productive approval hours/day)	Tiered: 60% of internal requests are Tier 1 (delegated sign-off ≈ 1 h + 0.5–2 h wait); the rest go to a rota of 3 approvers at large scale	Turnaround in working days (mean, 90th percentile)
2 Scope verification	Free-text target lists checked by eye (catches 80% of mis-scoped targets in small, 55% in large programme)	Asset-ID register check (S01), catches 99%	Mis-scoped targets caught
3 Disclosure	Flat 90-day window for every severity	Severity-tiered windows 30/45/90/120 days	Share of findings remediated inside the window (all and Critical)

These figures come from modelling assumptions (stated above), not from measurements at a real university; they show the direction and size of effects and should be recalibrated with real data.

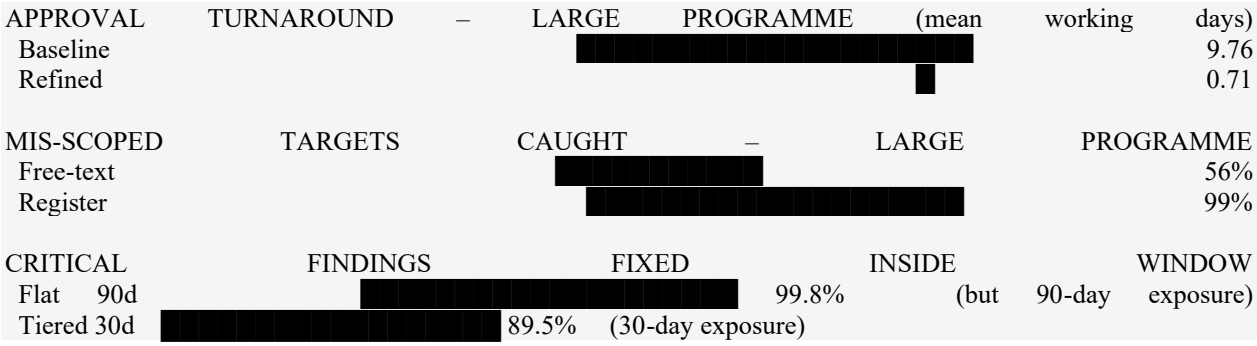
10.3 Comparison table (output of the simulation)

Measure	Small – baseline	Small – refined	Large – baseline	Large – refined
Approval turnaround, mean (working days)	0.52	0.34	**9.76**	**0.71**
Approval turnaround, 90th percentile	1.12	0.48	18.28	1.41
Mis-scoped targets per year	6	6	368	368
Mis-scoped targets caught	6 (100%)	6 (100%)	206 (56%)	**363 (99%)**
Requests needing the full	100%	about 40%	100%	about 61%

Measure	Small – baseline	Small – refined	Large – baseline	Large – refined
Board/CISO review (expected share)				

Disclosure design (large programme severity mix 10/25/40/25%)	Findings fixed inside window	Critical findings fixed inside window	Maximum exposure of a Critical finding
Flat 90-day window	78.2%	99.8%	90 days
Tiered 30/45/90/120 (v1.0 / v1.1)	76.9%	89.5%	30 days

10.4 Visualization (each ▉ = 5 percentage points; days in the first chart: each ▉ = 0.5 working day)



10.5 Interpretation and governance refinements driven by the evidence

1. **Approval does not scale with one approver.** At 60 requests a month the queue makes the mean wait almost 10 working days (90th percentile 18), which would delay the upgrade and push departments to test informally. Tiering plus a rota cut the mean to 0.71 days. **Refinement adopted (GR-09 made binding):** Tier-1 requests may be signed by system owner plus Security Lead; Tier-2/3 go to a 3-member rota with a 2-working-day service target.
2. **Scope checking by eye fails at scale.** Free-text lists catch only 56% of mis-scoped targets in the large programme (368 per year), against 99% for an Asset-ID register check. At small scale the difference disappears (100% in both, but only 6 events, so the sample is too small to conclude much). **Refinement adopted:** the Asset Register and scope manifest become mandatory for every engagement from day one, so the small programme grows into the large one without changing the process.
3. **Short windows cut exposure but lower the on-time rate.** Moving a Critical finding from a 90-day to a 30-day window shortens its exposure by 60 days while 89.5% are still fixed in time; the 10% that are not need a defined consequence. **Refinement adopted:** the overdue escalation ladder (Task 9, P4) and the single 50% extension rule for High/Medium findings.

These three decisions changed the framework (version 1.1), rather than just reporting numbers.

TASK 11 – Defend the Framework Under a Changed Requirement (5 Marks)

11.1 The changed requirement

The university now runs **continuous and third-party assessments**, under **stricter data-protection rules** and a **shorter disclosure timeline**, and wants a framework that remains **easy to govern and extend**. Version 1.1 assumed discrete, mostly internal engagements, each approved one by one.

Change	What breaks in v1.1
Continuous assessment	One approval per test does not scale: Task 10 shows 9.76 working days of waiting even at 60 requests a month with a single approver; recurring scans would multiply requests.
Third-party assessors	External testers raise trust, data-residency and supply-chain risks beyond the NDA and tier-3 rule (A09, A10).
Stricter data protection	DPO sign-off alone is not enough once DPDP duties (security safeguards, breach intimation, restrictions on transfer) commence on 13 May 2027.
Shorter disclosure timeline	Windows of 30/45/90/120 days become 15/30/60/90 days; Task 10 shows many findings would miss them.
Easy to govern/extend	Rules are spread over documents; each new component should plug in without rewriting others.

11.2 Retain, modify, replace or redesign

Component (task)	Decision	Reason
Threat model (T2)	**Modify**	Add profile H8 *compromised or malicious third-party assessor* (supply-chain actor) and an automated-scanner profile; classification rules unchanged.
Code of Conduct (T3)	**Modify**	Add rules for unattended or continuous tools (rate limits, kill switch, named human owner) and third-party clauses; principles P1–P10 retained.
Legal mapping (T4)	**Modify**	Add DPDP Rules-level controls with an effective-date switch (13 May 2027); IT Act rows retained; CFAA kept as benchmark.
Scope and RoE (T5)	**Modify**	RoE becomes a **standing RoE profile** plus a per-run manifest; Asset-ID boundaries retained.
Authorization workflow (T6)	**Redesign for Tier 1/2**	Per-test approval replaced by a **Standing Authorization Envelope**; Tier 3 keeps per-engagement approval.
Disclosure layer (T6)	**Modify**	Shorter windows, 24-hour triage, rapid-response lane, retained ladder and DR-1…DR-5 rules.
Isolated lab (T7)	**Retain**	Host-only containment is independent of the change;

Component (task)	Decision	Reason
		add automatic baseline reset before each rehearsal.
Document library (T8)	**Modify and extend**	New DOC-08 Standing Authorization, DOC-09 Third-Party Assessor Record, DOC-10 Data-Protection Check; Finding Report gains `lane` and `assessor_org`.
Manual log review (CoC-8)	**Replace**	Replaced by hash-chained logs with automatic reconciliation against the scope manifest.
Test harness and evaluation (T9, T10)	**Retain**	Re-run on the revised rules (regression).

11.3 New and modified components

N1 – Standing Authorization Envelope (SAE), replaces per-test approval for Tier 1 and 2. A single signed record that allows a fixed set of assets, techniques and windows to be assessed repeatedly.

Rule	Content
SA-1	Valid for at most 90 days; renewal needs review of all runs and findings in that period.
SA-2	Only Tier 1/2 techniques (passive, discovery, vulnerability scan); any Tier-3 technique needs a normal engagement approval.
SA-3	Assets are listed by Asset ID with owner confirmation; personal-data assets need DPO sign-off *inside the envelope*.
SA-4	Automatic suspension if the asset register changes, an unplanned alert occurs, or a Stop Report is raised.
SA-5	Each run produces a log line `(SA-ID, run-ID, asset, technique, time)` checked by `check_action_v11`.
SA-6	Rate limits and windows are part of the envelope; every run has a named human owner.

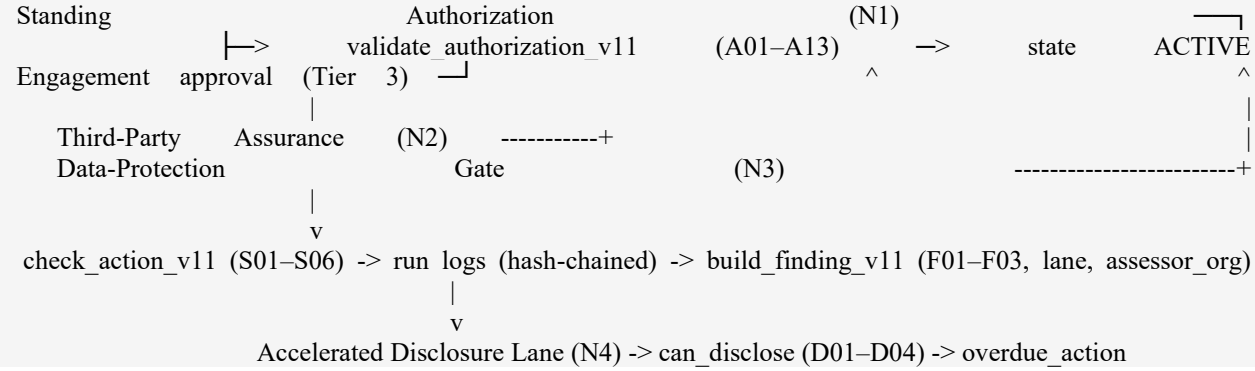
N2 – Third-Party Assessor Assurance (TPA). Before any external assessor receives an SA or engagement: (1) vendor due diligence and references; (2) contract with clauses on confidentiality, data residency in India, breach notification within 2 hours, deletion within 30 days, no subcontracting without approval, audit right and liability; (3) named individuals with personal accounts; (4) access only through an India-hosted jump host with session recording; (5) default Tier 3 for first six months, then Tier 2 on a good record; (6) annual re-vetting. Rules A09, A10 and A13 enforce the minimum automatically.

N3 – Data-Protection Gate (DPG). Placed between W4 and W5 of the workflow. Checks: (1) can the test run on masked staging instead of production? (2) data classification of each asset; (3) DPO clearance recorded; (4) evidence minimization (≤ 3 masked records) and encrypted storage; (5) retention of 30 days after closure, logs 180 days; (6) breach-intimation path to the Data Protection Board and affected persons, plus the CERT-In 6-hour report where applicable (Legal to confirm exact timelines under the DPDP Rules 2025). A DPG result is stored in the register and is a precondition for SA and engagement approval.

N4 – Accelerated Disclosure Lane. New windows: **Critical 15, High 30, Medium 60, Low 90 days**. Triage within 24 hours of validation; owner pre-notified at validation (not after the report); named on-call

fixer for Critical/High; one extension of up to 50% for High/Medium; the overdue ladder (CISO, Board, limited advisory) starts the day after the due date; DR-1…DR-5 unchanged.

11.4 How the new components integrate with the existing framework



Integration is through the same identifiers: SA-ID or Engagement ID, Asset ID, Finding ID. The scope guard accepts either an SA or an engagement as the authority; the finding report adds only two new fields; N2 and N3 feed existing rules (A07, A09, A10, A13, D03) rather than creating parallel processes. No v1.1 component had to be rewritten.

11.5 Defence of the final framework using evidence

Requirement	Design response	Evidence
Continuous assessment	SAE for Tier 1/2, individual approval for Tier 3	**Scalability (Task 10):** per-request approval already took 9.76 days at large scale; tiering cut it to 0.71 days; SAE removes the per-run approval altogether. **Walkthrough (Task 9):** S06 stops anything that is not ACTIVE.
Third-party assessors	N2 plus A09, A10, A13	**Tests TC-6 and TA-I4** show a foreign or un-NDA'd external tester is rejected until conditions are met. **Task 4:** CFAA benchmark and s.43 owner permission.
Stricter data protection	N3 plus L-C3, L-C9, D03, evidence minimization	**Legal mapping (Task 4):** each DPDP/IT Act duty has a control; **tests TA-I1, TC-10** show missing DPO clearance blocks approval and disclosure.
Shorter disclosure timeline	N4: 15/30/60/90 days, 24-hour triage, ladder	**Disclosure simulation:** with current remediation speeds only 68.9% of all findings and 54.4% of Critical ones meet the new windows (even with the extension rule); a what-if with a rapid-response lane (median fix times Critical 7, High 20, Medium 45, Low 80 days) gives **81.6% overall and 89.5% for Critical**. This is a projection based on assumed fix speeds that must be confirmed by measuring real fix times. **Tests TC-9** show the ladder.

Requirement	Design response	Evidence
Easy to govern and extend	ID-based coupling, rules in one file, versioned documents	Adding N1–N4 changed rules A13, S06, F03 and the ladder only; v1.0 tests still pass. A quarterly review uses four KPIs: approval turnaround, mis-scoped targets caught, % findings fixed in window, number of Stop Reports.

11.6 Remaining trade-offs and limitations, with future improvements

#	Trade-off or limitation	Why it remains	Future improvement
1	**Speed vs control:** the SAE lowers human review for routine scans, so scope drift or a wrong asset-owner confirmation could go unnoticed between renewals	Needed to make continuous testing feasible; mitigated by SA-4 auto-suspension, but still depends on an accurate Asset Register	Link the register to a configuration database (CMDB) so changes suspend the envelope automatically; sample audits of runs
2	**Shorter windows vs remediation capacity:** even with the lane, roughly one fifth of findings (≈ 18%) would miss the new windows in the what-if, and Critical results rely on an assumed faster fix speed	System owners may lack staff, so deadlines can turn into risk-acceptance paperwork	Fund a remediation team; track mean fix time per owner; use risk-acceptance forms signed by the Board
3	**Evidence is simulated:** Task 10 uses modelling assumptions (service times, mis-scope rates, remediation times) rather than real university data; the scope sample at small scale is only six events	No production data exists before the programme starts	Re-run Appendix B with real logs after the first quarter and recalibrate
4	**Tooling is documents and small scripts:** forms, signatures and logs are partly manual, so effort grows with volume	A student-built reference implementation, not a platform	Move the rules into a ticketing/GRC tool with e-signatures and signed logs
5	**Bug bounty deferred:** third-party researchers outside contracted assessors have no safe channel except CERT-In	Needs legal safe-harbour terms and triage staff	Start a private, invitation-only vulnerability-disclosure programme once metrics are stable
6	**Legal position is a snapshot:** DPDP provisions commence in stages (13 May 2027 for the main duties) and rules may be amended	Law is still being operationalised	Legal Counsel reviews the mapping each quarter and on any notification; the effective-date switch in Task 4 avoids redesign

11.7 Conclusion

The final framework (version 2.0 = v1.1 + N1–N4) separates what is **authorized** (signed envelope or engagement), **legal** (A, F, D rules that embody IT Act, DPDP and contract duties) and **appropriate** (Code of Conduct and RoE prohibitions), connects them through three identifiers, and has evidence for each decision: approval time of 0.71 days instead of 9.76 at university scale, 99% scope-error detection, and a disclosure process with an explicit escalation ladder. Remaining limitations are stated openly with a plan to measure and improve them.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5
TASK 8 – Develop	5
TASK 9 – Integrate	5
TASK 10 – Create	5

TASK 11 – Defend	5
TOTAL	**50**